

Cybersecurity Ethics



Nancy LaTourrette
Computer Science & Engineering

Cybersecurity Ethics

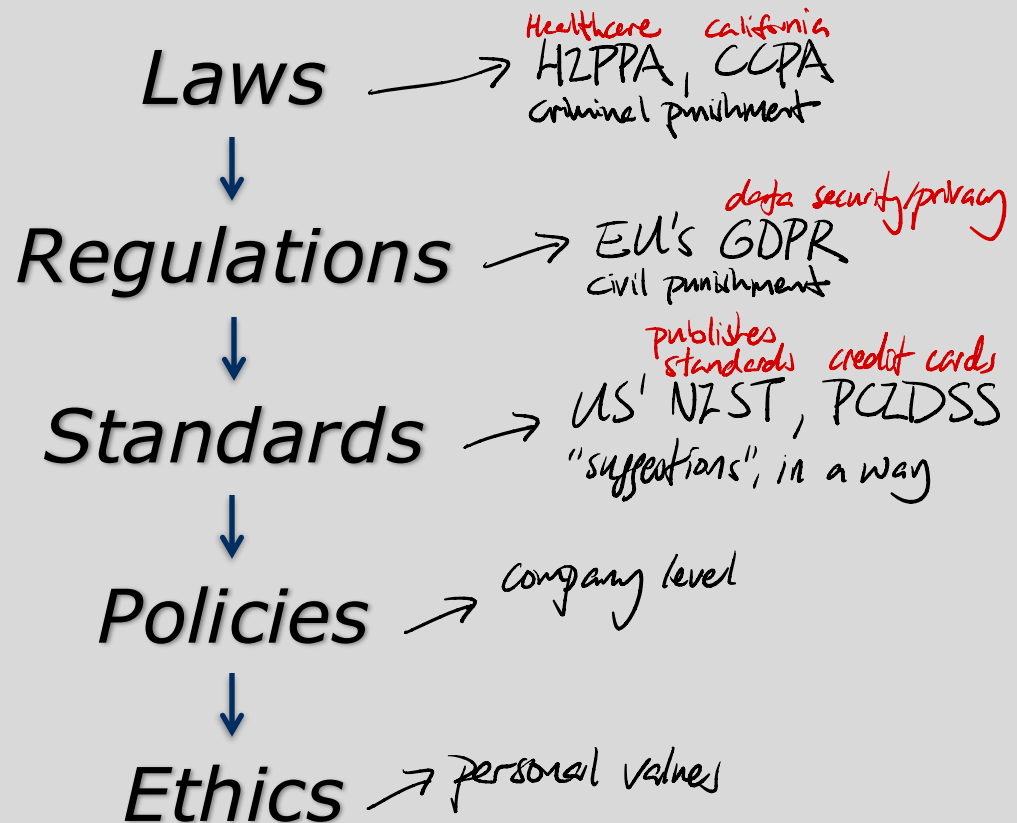
"Ethics: The information systems and the security of information systems should be provided and used in such a manner that the rights and legitimate interests of others are respected." *don't abuse systems and their security measures to harm others*

-- NIST, Special Publication 800-14, 1996

"You can not promote the (true) idea that security research benefits humanity while defending research that endangered hundreds of innocents." *you can't be hypocritical*

-- Alex Stamos, Former Yahoo CISO, Tweet 2015

Procedures



General vs Cybersecurity Ethics

General Computing Ethics

- Integrity
- Objectivity
- Professional Competence
- Due Care
- Confidentiality

Cybersecurity Ethics

- Integrity
- Objectivity
- Professional Competence
- Due Care
- Confidentiality
- "To know how to protect something, you have to know how to break it" [Suzanne Mello Stark] *know something inside-out*

note similarity



Definitions

Hacker- An unauthorized user who attempts to or gains access to an information system.

Ethical Hacker- Hackers hired by an organization to penetrate networks and computer systems with the purpose of finding and fixing security vulnerabilities.

Hacktivist- The subversive use of computing systems to promote a political agenda, often related to free speech or freedom of information movements. *Think Anonymous*

White Hat- An ethical hacker or security expert, who specializes in penetration testing to ensure the security of an organization's information systems.

Definitions

Black Hat- A hacker who "violates computer security for little reason beyond maliciousness or for personal gain". [Richard Stallman]

Grey Hat- Hackers who look for vulnerabilities in a system without permission. Will report flaws to the owner, sometimes requesting a fee to fix the issue.

Honey Pot- Decoy servers or systems setup to gather information regarding an attacker or intruder into a system.

Pen Testing- An evaluation where assessors search for vulnerabilities and attempt to circumvent the security features of a network and/or information system.

Definitions

Vulnerability Assessment- Assessment of threats and vulnerabilities, deviations from policy, level of risk, and development and/or recommendation of appropriate mitigation countermeasures.

Zero-Day Exploit- A threat actor spots a vulnerability either before the developer does or acts on it before the developer has a chance to fix it.

Full/Responsible Disclosure– Exposing vulnerabilities publicly and immediately or notifying organizations first to allow for a patch.

Definitions

Cyber/Data Breach- A security incident in which sensitive, protected or confidential data is copied, transmitted, viewed, stolen or used by an unauthorized individual unauthorized.

Red Team- An exercise conducted as a simulated attempt by an adversary to attack or exploit vulnerabilities in an organization's information systems.

Blue Team- A group that defends an organization's information systems when mock attackers (i.e., the Red Team) attack, typically as part of an operational exercise.

Table Top Exercises

Talking about & planning for potential scenarios can be useful

I. Credit Card Breach

II. Student SQL Injection

- Team discussion
 - ❖ Clarify Scenario
 - ❖ Legal Considerations
 - ❖ Ethical Considerations
 - ❖ Talking Points
- Group discussion

ETHICAL CONSIDERATIONS

UNIVERSITY OF X
CREDIT CARD BREACH

TABLE TOP EXERCISE

Incident Description

- University Police are notified by the Secret Service that a series of credit card numbers have been compromised and the common merchant account belongs to U of X.
- The merchant number is tied back to the Athletics department and it is discovered that Information Security was never notified that this new merchant account was requested and issued.
- Upon further investigation, it is determined that the account is tied to a server running in the Athletics department.
- This is deemed a “Special Response” incident, due to the fact that card holder data (CHD) is involved.

Considerations

- What could happen if the breach could not be immediately contained?
- What forensic considerations should be made?
- Is there a risk of continuing related operations?
- Who needs to be notified, both internally and externally?
- Are formal notifications required by law?
- If so, how will notifications to individuals be handled with no current contact information?
- When should systems be restored?
- Are there other potential risks related to the source of the incident?

1. Financial loss, reputation damage, Legal issues, and prolonged breach

2. Data preservation, incident timeline, Malware Analysis, Access logs

3. Further compromise, increased liability, operational disruption

4. Internal: Admin, IT/Security, Athletics, incident response
External: Affected people, credit card companies, law enforcement

5. Most likely, but refer to data protection laws/regulations

6. public announcements and contact information

7. post-investigation, post-security patching, management approval

8. insiders, 3rd-party vendors, general compliance

Considerations (cont'd)

- Besides the incident response team, what external departments should be involved?
- What steps should be taken internally to control external communications?
- How would a breach of this magnitude affect U of X's reputation and can it be mitigated? If so, how?

9. Legal, PR, etc.

10. Centrally organize internal/external communication, e.g. use a spokesperson/monitor media

11. loss of trust, less popularity, mitigated by transparency, direct communication/engagement

Incident Update

- Upon further review of systems it is determined that an event registration application being run by the Athletics department has been compromised.
- The event is in it's last day of registration and Athletics expects \$100,000 in registration revenue by end of day.

New Considerations

- Should any of the previous decisions be changed given the update?
- If donor information was compromised are there special considerations or notifications to be made?
- Anything else to consider?

ETHICAL CONSIDERATIONS

UNIVERSITY OF X
STUDENT INCIDENT

TABLE TOP EXERCISE

Incident Description

- Information Security is notified by operations that system logs for the Fitness Center application indicate an individual used a SQL injection attack to download all the data contained in the application.
- The IP address of the attacker corresponds to an address on the U of X wireless network.
- The MAC address of the laptop involved in the attack traces back to a student.
- The laptop is currently online in a building located on campus.
- Student is currently physically located in the building.
- Student claims she was participating in an exercise for a Cybersecurity class.
- Student claims she did not know what she was doing and has deleted all of the downloaded data.
- Student is remorseful and visibly upset.

Considerations

- What steps should be taken?

Investigation, Interview, Data Recovery, Documentation

- Who should be notified?

Admin, IT/Security, Regulatory bodies

- Would it make a difference if the student was currently employed as a student worker?

Policy violations

- Would the job description make a difference?

Yes, if the job was inherently technical then it may be more serious

- Is this incident ethically different from Exercise 1? Why or Why not?

intent, cooperativeness, education

Paper Discussion

Teaching Hacking and Ethics

- Read paper: *The Ethics of Hacking: Should It Be Taught?*
- Does this influence your answers to Table Top Exercises?
- Group discussion

References

[1] NIST, Special Publication 800-14, Generally Accepted Principles and Practices for Securing Information Technology Systems, 1996

[2] 10 Ethical Issues Confronting IT Managers, TechRepublic
<http://www.techrepublic.com/article/10-ethical-issues-confronting-it-managers/>

[3] Should Hacking be Taught arXiv.org
<https://arxiv.org/ftp/arxiv/papers/1512/1512.02707.pdf>

[4] Definition of Security Ethics, TechTarget
<http://searchsecurity.techtarget.com/feature/Spotlight-article-Domain-8-Laws-Investigations-and-Ethics>

[5] Unified Framework of Professional Ethics for Security Professionals,
<http://ethics-wg.org/framework.html>

Acknowledgements

This material is based upon work supported by the National Science Foundation under Grant No. 1542465.

